

Arsitektur Keamanan & Model Ancaman (STRIDE)

dashAI — Saksi Mata Digital yang Netral & Tertandatangan

dashAI

2026-06-21

Daftar Isi

1	Ringkasan Eksekutif	1
2	Sasaran Keamanan	2
3	Aset & Batas Kepercayaan	4
3.1	Aset	4
3.2	Batas Kepercayaan	6
4	Diagram Aliran Data dengan Batas	8
5	Analisis STRIDE	9
5.1	Spoofing (Pemalsuan identitas / asal)	10
5.2	Tampering (Perusakan integritas)	11
5.3	Repudiation (Penyangkalan)	13
5.4	Information disclosure (Kebocoran informasi)	14
5.5	Denial of service (Penolakan layanan)	17
5.6	Elevation of privilege (Peningkatan hak akses)	18
6	Manajemen Kunci (DASHAI_SIGNING_KEY)	19
6.1	Bentuk & pemuatan	19
6.2	Dev vs Prod	19
6.3	Prinsip & prosedur kunci	19
7	Apa yang Dibuktikan vs Tidak Dibuktikan Tanda Tangan	20
7.1	Yang DIBUKTIKAN tanda tangan (✓)	20
7.2	Yang TIDAK dibuktikan tanda tangan (✗)	20
8	Peta Jalan Pengerasan (Hardening Roadmap)	20
9	Mitigasi Dipetakan ke Temuan & Perbaikan Audit	22
9.1	Perbaikan audit 1 — Validasi input di /api/seal	22
9.2	Perbaikan audit 2 — Tanda tangan diverifikasi sebelum laporan dibuat (signature-before-report)	22
9.3	Matriks ringkas temuan → kontrol	23
10	Asumsi & Keterbatasan Demo	24

1 Ringkasan Eksekutif

Dokumen ini memodelkan permukaan keamanan dashAI secara menyeluruh: aset yang dilindungi, batas kepercayaan yang dilintasi data, ancaman per kategori STRIDE (Spoofing,

Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege), serta mitigasi yang sudah diterapkan dan yang masih menjadi peta jalan (roadmap).

Postur keamanan dashAI dibentuk oleh dua kenyataan arsitektural yang menentukan seluruh analisis:

1. **Seluruh deteksi berjalan di klien (browser).** TensorFlow.js coco-ssd, IoU tracker, MediaPipe face/pose, dan Tesseract.js OCR pelat semuanya dijalankan di perangkat pengguna. Server **tidak pernah** menerima aliran kamera; ia hanya menerima satu objek EvidencePayload yang **secara eksplisit disegel** oleh pengguna. Konsekuensinya, klien bersifat **tidak tepercaya penuh**.
2. **Permukaan server sengaja minimal.** Empat endpoint (/api/seal, /api/verify, /api/report, /api/public-key), tanpa basis data, tanpa autentikasi pengguna, tanpa kunci API pihak ketiga. **Satu-satunya rahasia** adalah DASHAI_SIGNING_KEY (seed Ed25519). Permukaan serang yang kecil adalah pilihan keamanan yang disengaja.

Klaim integritas dashAI bersifat **tamper-evident, bukan tamper-proof**. Tanda tangan Ed25519 membuktikan bahwa isi laporan **tidak berubah satu byte pun** sejak disegel server pada waktu tertentu; ia **tidak** membuktikan bahwa kamera benar-benar menyaksikan peristiwa di dunia nyata. Bagian Apa yang Dibuktikan vs Tidak Dibuktikan Tanda Tangan menjabarkan batas kejujuran ini secara rinci.

Catatan status. dashAI saat ini adalah **demonstrasi teknologi lewat kamera ponsel**. Laporan yang dihasilkan **bukan** dokumen resmi kepolisian. Model ancaman ini menulis batasan demo secara jujur dan memisahkan dengan tegas antara mitigasi yang sudah aktif (Implemented) dan yang direncanakan (Roadmap).

2 Sasaran Keamanan

Sasaran keamanan dashAI diturunkan langsung dari tujuan produknya: menjadi **saksi mata digital yang netral** yang melindungi pengendara dari fitnah, tilang palsu, dan amuk massa, sekaligus dapat menindak pelanggar lain. Karena bukti dashAI harus bertahan dalam konteks adversarial (pihak yang dirugikan akan berkepentingan untuk membantahnya), integritas dan verifikasiabilitas adalah pilar utama.

#	Sasaran	Properti CIA / Lainnya	Bagaimana dicapai
O1	Integritas bukti — isi laporan yang disegel tidak dapat diubah tanpa terdeteksi	Integrity	Canonicalisation + SHA-256 + tanda tangan Ed25519 (lib/crypto/); verifySealed menjalankan dua pemeriksaan independen
O2	Verifiabilitas oleh pihak ketiga — siapa pun dapat memverifikasi tanpa memercayai UI dashAI	Integrity, Transparency	Kunci publik dipublikasikan di /api/public-key; halaman /verify memverifikasi di sisi klien; envelope tersemat penuh di QR/URL (tanpa lookup basis data)
O3	Non-repudiation asal seal — setiap envelope dapat dilacak ke instans dashAI yang menyegelnya pada waktu otoritatif	Accountability	sealedAt distempel server; publicKeyId (prod-/dev-) tertanam di tiap envelope
O4	Kerahasiaan kunci penandatanganan — private key tidak pernah meninggalkan server	Confidentiality	DASHAI_SIGNING_KEY dibaca via process.env di runtime Node; modul sign.ts ditandai import "server-only"
O5	Privacy-by-design — data pribadi diminimalkan; subjek tidak diidentifikasi	Confidentiality, Compliance (UU 27/2022)	Face detection bukan recognition ; blur-by-default; penyimpanan lokal-dulu (IndexedDB); koordinat dibulatkan sebelum dikirim ke pihak ketiga
O6	Kebenaran landasan hukum	Integrity (data)	Knowledge base UU 22/2009 diverifikasi adversarial 3-voter (12/12), digenerate Pabelin tamper-evident buktikan dari docs/research/phase0-tamper-evident/secondary_READSM_research.json; server Overpass dan rapor model develop tidak menolok violation yang tidak dapat ditelusuri dan tidak ada di CITATIONS
O7	Keterbacaan — sitasi yang terdegradasi pasai bukan angsun tidak hafusinasi kenaklaim model lebih banyak yang dapat	Integrity (kepercayaan)	3
O8	Keterbacaan — sitasi yang terdegradasi pasai bukan angsun tidak hafusinasi kenaklaim model lebih banyak yang dapat	Integrity (kepercayaan)	3

Non-sasaran (out of scope) untuk fase demo saat ini:

- **Anti-pemalsuan adegan fisik.** dashAI tidak menjamin bahwa kamera menyaksikan peristiwa nyata (lihat O8 dan bagian tamper-evidence). Mitigasi diserahkan ke roadmap (device attestation, kontinuitas GPS).
 - **Autentikasi/otorisasi pengguna.** Tidak ada akun pengguna, sesi, atau RBAC; permukaan server bersifat tanpa-status (stateless) dan publik secara desain.
 - **Kerahasiaan media bukti di transit ke server.** Media tidak dikirim ke server; hanya hash SHA-256-nya yang masuk ke payload yang disegel.
-

3 Aset & Batas Kepercayaan

3.1 Aset

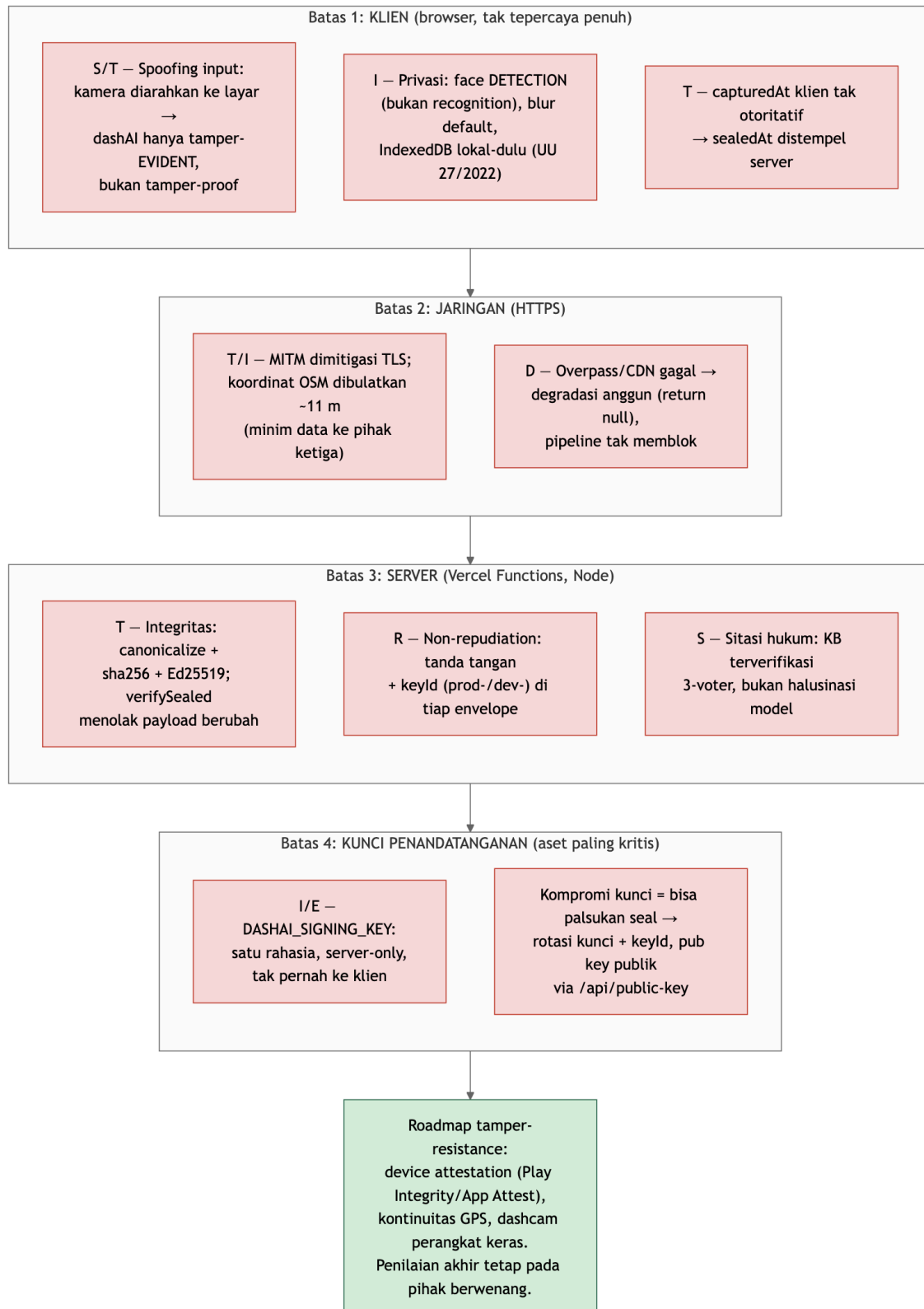
Aset diurutkan berdasarkan kekritisannya terhadap misi “bukti yang tidak bisa dibantah”.

ID	Aset	Lokasi	Kekritisn	Dampak bila dikompromikan
A1	DASHAI_SIGNING_KEY (private Ed25519 seed)	var server (Vercel), in- memory cached di keys.ts	Kritis tertinggi	Penyerang dapat memalsukan seal yang valid → seluruh jaminan integritas runtuh
A2	EvidencePayload tersegel (SealedEvidence)	Dibuat di server, disimpan di IndexedDB klien, tertanam di QR/PDF	Tinggi	Inti nilai bukti; integritasnya yang dijamin tanda tangan
A3	Knowledge base hukum (CITATIONS) (generated, verified)	lib/ citations.ts (generated, verified)	Tinggi	Sitasi salah merusak kredibilitas hukum & legitimasi laporan
A4	Media bukti (frame, faceCrop, plateCrop)	Klien (object URL / data URL), hanya hash masuk payload	Sedang	Memuat data pribadi (wajah, pelat); risiko privasi bila bocor
A5	Data lokasi & telemetri (GeoPoint, kecepatan, heading)	Klien; sebagian masuk payload	Sedang	Lokasi presisi adalah data pribadi (UU 27/2022)
A6	Kunci publik & keyId	/api/ public- key, tiap envelope	Rendah (publik secara desain)	Bukan rahasia; integritas distribusinya yang penting
A7	Reputasi & klaim integritas dashAI	Lintas- sistem	Tinggi	Overclaiming (mis. “tamper-proof”) merusak kepercayaan secara permanen

3.2 Batas Kepercayaan

dashAI melintasi empat batas kepercayaan yang berbeda. Penomoran ini konsisten dengan diagram model ancaman.

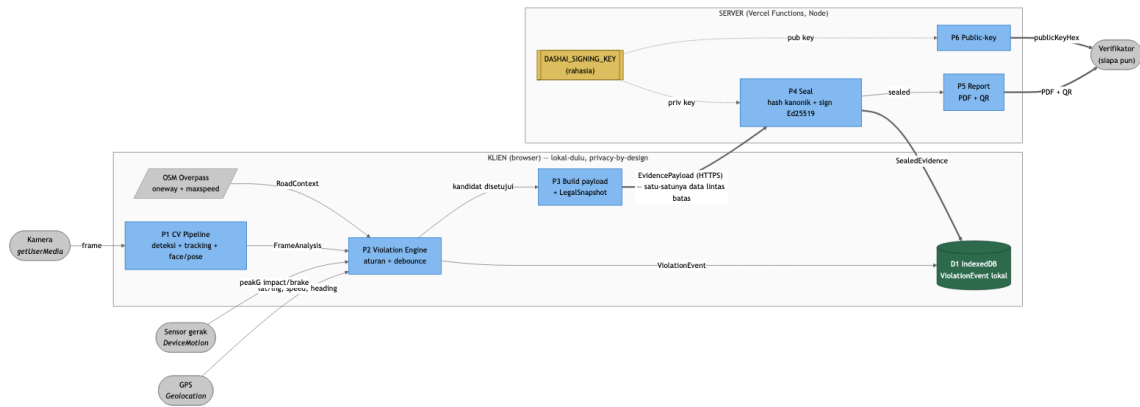
- **Batas 1 — KLIEN (browser / ponsel).** Tidak tepercaya penuh. Semua deteksi, penyimpanan lokal IndexedDB, dan pembuatan payload terjadi di sini. Penyerang yang menguasai klien dapat memanipulasi input kamera (mengarahkan ke layar), memodifikasi nilai sebelum seal, atau mencuri media lokal.
- **Batas 2 — JARINGAN (HTTPS).** Antara klien dan server, serta antara klien dan layanan publik (OSM Overpass, CDN model). Ancaman MITM dimitigasi TLS.
- **Batas 3 — SERVER (Vercel Functions, runtime Node).** Tepercaya untuk menyegel, memverifikasi, dan merender laporan. Inilah satu-satunya tempat private key berada.
- **Batas 4 — KUNCI PENANDATANGANAN.** Sub-batas paling kritis di dalam server. DASHAI_SIGNING_KEY dibaca dari env, di-cache in-memory, dan tidak pernah diserialisasi ke respons mana pun.



Gambar 1: Model ancaman dashAI lintas batas kepercayaan (STRIDE)

4 Diagram Aliran Data dengan Batas

Diagram aliran data (DFD) memperlihatkan bahwa **satu-satunya data yang melintasi batas klien→server adalah EvidencePayload melalui HTTPS** (panah tebal). Semua proses CV, tracking, dan pembentukan payload tetap di klien; OSM Overpass diakses langsung dari klien (bukan diproksi server).



Gambar 2: Diagram aliran data dashAI dengan batas kepercayaan klien | server

Pengamatan keamanan dari DFD:

- **Aliran lintas-batas tunggal.** Hanya P3 Build payload → P4 Seal yang melewati batas jaringan ke server. Tidak ada media (frame/wajah/pelat) yang dikirim — hanya mediaHashes (SHA-256) ikut di payload, sehingga server tidak pernah menyimpan citra pribadi.
- **Rahasia terisolasi.** DASHAI_SIGNING_KEY hanya menyentuh P4 Seal (private key) dan P6 Public-key (hanya bagian publik diturunkan). Tidak ada jalur dari rahasia ke klien.
- **Verifiabilitas tanpa-status.** P5 Report menyematkan seluruh SealedEvidence di QR/URL, sehingga verifikator dapat memverifikasi tanpa memanggil basis data dashAI — menghilangkan satu permukaan serang sekaligus satu titik kegagalan ketersediaan.

Aliran	Dari → Ke	Batas dilintasi	Data
Frame	Kamera → P1 CV Pipeline	dalam klien	Pixel video (tidak pernah keluar)
GPS/sensor	Geolocation/ DeviceMotion → P2 Engine	dalam klien	lat/lng, speed, heading, peak-G
Konteks jalan	OSM Overpass → P2 Engine	klien ↔ pihak ketiga (HTTPS)	RoadContext (oneway, maxspeed); koordinat dibulatkan ~11 m
Payload	P3 → P4 Seal	klien → server (HTTPS)	EvidencePayload (satu-satunya lintas batas)
Private key	env → P4 Seal	dalam batas kunci (server)	Seed Ed25519
Sealed	P4 → IndexedDB / P5 Report	server → klien	SealedEvidence (signature, payloadHash, keyId)
Public key	P6 → Verifikator	server → publik	publicKeyHex, keyId, algoritma
Laporan	P5 → Verifikator	server → publik	PDF + QR yang menyematkan envelope penuh

5 Analisis STRIDE

Setiap temuan diberi ID (S-, T-, R-, I-, D-, E-), batas kepercayaan tempat ancaman berada, status mitigasi (**Implemented** = sudah ada di kode, **Roadmap** = direncanakan), dan referensi kode/dokumen yang membuktikannya.

5.1 Spoofing (Pemalsuan identitas / asal)

ID	Ancaman	Batas	Mitigasi	Status
S-1	Kamera diarahkan ke layar / rekaman , sehingga “peristiwa” yang disegel tidak terjadi di dunia nyata	1 (Klien)	Diakui secara eksplisit: dashAI tamper-EVIDENT, bukan tamper-proof . Penilaian akhir tetap pada pihak berwenang. Mitigasi teknis (device attestation, kontinuitas GPS) ada di roadmap	Roadmap
S-2	Pemalsuan kunci publik – verifikator dibujuk memakai kunci publik palsu yang cocok dengan seal palsu	2/4	Kunci publik disajikan via GET /api/public-key di atas TLS; keyId (prod-/dev-) tertanam di tiap envelope sehingga ketidakcocokan kunci terdeteksi	Implemented
S-3	Penyamaran instans dev sebagai produksi – laporan dari kunci DEV diperlakukan otoritatif	4	Kunci DEV bersifat tetap & publik di kode; keyId berawalan dev-; isDev diteruskan ke /api/report dan ditandai pada PDF	Implemented
S-4	Sitasi hukum palsu – pelanggaran fiktif disegel dengan pasal halusinasi	3	KB terverifikasi 3-voter (12/12); server menolak event.violation yang tidak ada di CITATIONS (HTTP 400) sebelum menyegel	Implemented

Catatan S-1: Karena frame berasal dari klien yang tidak tepercaya, **tidak ada** mekanisme kriptografis murni yang dapat membuktikan provenans fisik adegan. Ini adalah batas fundamental dari setiap bukti berbasis klien, dan dashAI memilih menyatakannya secara terbuka alih-alih menyembunyikannya.

5.2 Tampering (Perusakan integritas)

ID	Ancaman	Batas	Mitigasi	Status
T-1	Mengubah isi laporan (pelat/kecepatan/pasal) setelah disegel	1/2	canonicalize() → sha256HexString() → ed.signAsync().verifySealed menjalankan dua cek: hash kanonik cocok dan tanda tangan valid; satu byte berubah → hash tidak cocok → terdeteksi	Implemented
T-2	capturedAt klien dipalsukan untuk menggeser waktu kejadian	1	Server menstempel sealedAt = Date.now() yang otoritatif di /api/seal; buildPayload tidak pernah memercayai waktu seal dari klien	Implemented
T-3	Injeksi field/nilai liar ke payload (mis. confidence di luar 0..1, tipe salah)	3	Validasi input di /api/seal: cek kelengkapan (id/violation/subject/capturedAt), violation in CITATIONS, subject ∈ {self, other}, typeof capturedAt === number, dan clamp confidence ke [0,1]	Implemented
T-4	MITM mengubah payload/respons di transit	2	HTTPS/TLS pada seluruh trafik (Vercel); integritas end-to-end tetap diverifikasi oleh tanda tangan meski TLS ditembus	Implemented
T-5	Manipulasi RoadContext dari OSM (mis. maxspeed salah) memengaruhi perhitungan engine	2	OSM hanya input deteksi , bukan bagian otoritatif dari klaim; parseMaxspeed defensif; kegagalan	Implemented (parsial)
T-6	Perubahan KB hukum di sumber (citations.ts di-hand-edit)	3	File tidak di generate, memicu false positive; estimasi kecepatan berdasarkan flow data diverifikasi (pembagi kecepatan); replikasi	Implemented (proses)

5.3 Repudiation (Penyangkalan)

ID	Ancaman	Batas	Mitigasi	Status
R-1	Penyangkalan asal seal — pihak menolak bahwa envelope berasal dari dashAI	3/4	Tanda tangan Ed25519 + publicKeyId di tiap SealedEvidence mengikat envelope ke kunci penandatanganan; verifikasi publik memungkinkan pembuktian independen	Implemented
R-2	Ambiguitas waktu — kapan bukti disegel diperdebatkan	3	sealedAt distempel server dan termasuk dalam payload yang ditandatangani , sehingga waktu seal tidak dapat diubah tanpa membatalkan tanda tangan	Implemented
R-3	Tidak ada audit trail server-side untuk operasi seal (tanpa basis data)	3	Diterima sebagai trade-off privasi/kesederhanaan: verifikasi berpindah ke envelope itu sendiri (self-contained). Logging seal/rotasi adalah item roadmap	Roadmap

Catatan R-1: Non-repudiation di sini bermakna “**envelope ini disegel oleh pemegang DASHAI_SIGNING_KEY pada sealedAt**” — bukan “individu X mengakui melanggar”. Ini sengaja dibatasi sesuai O3.

5.4 Information disclosure (Kebocoran informasi)

ID	Ancaman	Batas	Mitigasi	Status
I-1	Kebocoran private key ke klien/log	4	DASHAI_SIGNING_KEY hanya dibaca di runtime Node; sign.ts memakai import "server-only"; hanya getPublicKeyInfo() yang diekspos ke klien	Implemented
I-2	Pengenalan wajah / identifikasi subjek	1	dashAI melakukan face detection (MediaPipe BlazeFace short-range) untuk crop+blur saja, bukan recognition ; tidak ada pencocokan ke identitas	Implemented
I-3	Eksfiltrasi media pribadi (wajah, pelat) ke server	1/2	Media tidak dikirim ke server; hanya mediaHashes (SHA-256) masuk payload; penyimpanan lokal-dulu (IndexedDB)	Implemented
I-4	Kebocoran lokasi presisi ke pihak ketiga (OSM)	2	Koordinat dibulatkan ke 4 desimal (~11 m) sebelum dikirim ke Overpass; hasil di-cache per sel grid ~11 m sehingga jumlah kueri eksternal minimal	Implemented
I-5	UI mengekspos data sensitif secara default	1	Blur-by-default pada wajah & pelat di antarmuka tinjauan	Implemented
I-6	Verbose error membocorkan internal	3	Respons error API ringkas & berbahasa pengguna (mis. "Body JSON tidak valid."); tidak membocorkan stack/konfigurasi	Implemented

Kepatuhan: pola di atas selaras dengan semangat **UU No. 27 Tahun 2022 tentang Pelindungan Data Pribadi (PDP)** – minimisasi data, pemrosesan lokal, dan penyegelan hanya atas tindakan eksplisit pengguna.

5.5 Denial of service (Penolakan layanan)

ID	Ancaman	Batas	Mitigasi	Status
D-1	Overpass / CDN model tidak tersedia melumpuhkan deteksi	2	Degradasi anggun: resolveRoadContext mengembalikan null pada kegagalan jaringan/parse (timeout 8 s); pipeline CV membungkus tiap model sekunder sehingga live view tetap jalan dengan model yang berhasil dimuat	Implemented
D-2	Payload besar / abuse ke /api/ seal	2/3	Server hanya memproses satu payload kecil per permintaan; rendering PDF dibungkus try/ catch (HTTP 500 alih-alih crash). Rate limiting/WAF lapis platform adalah item roadmap	Implemented (parsial)
D-3	Render PDF gagal / payload merusak menjatuhkan fungsi	3	/api/report membungkus renderToBuffer dalam try/catch; kegagalan QR bersifat best-effort (URL tetap dicetak)	Implemented
D-4	Beban inferensi CV berlebih di perangkat lemah	1	Debounce 6 s per (violation, track), MIN_TRACK_AGE 4 frame untuk membuang noise satu- frame; model sekunder opsional	Implemented

5.6 Elevation of privilege (Peningkatan hak akses)

ID	Ancaman	Batas	Mitigasi	Status
E-1	Pengguna klien memperoleh kemampuan menyegel sendiri (mengakses private key)	4	Private key tidak pernah meninggalkan server; tidak ada jalur kode dari klien ke priv; server-only mencegah impor sign.ts ke bundle klien	Implemented
E-2	Penyalahgunaan endpoint server tanpa autentikasi	3	Permukaan sengaja minimal & tanpa-status; tiap endpoint hanya melakukan satu operasi terbatas dengan validasi input; tidak ada operasi istimewa yang dapat di-eskalasi	Implemented
E-3	Eskalasi via violation tak dikenal memicu jalur kode tak tervalidasi	3	Guard violation in CITATIONS di /api/seal dan /api/report mencegah pemrosesan jenis pelanggaran asing	Implemented
E-4	Kompromi kunci → kemampuan memalsukan semua seal	4	Bila kunci bocor, penyerang memperoleh kemampuan setara server. Mitigasi: rotasi kunci (ganti DASHAI_SIGNING_KEY), keyId baru, dan publikasi ulang via /api/public-key; envelope lama tetap dapat dipisahkan berdasarkan keyId	Implemented (prosedur)

6 Manajemen Kunci (DASHAI_SIGNING_KEY)

6.1 Bentuk & pemuatan

DASHAI_SIGNING_KEY adalah **seed Ed25519 32-byte yang dikodekan hex (64 karakter)** — satu-satunya rahasia yang dibutuhkan dashAI. Pemuatannya dikelola di `lib/crypto/keys.ts`:

- Nilai dibaca dari `process.env.DASHAI_SIGNING_KEY`, di-`trim()`, lalu divalidasi dengan regex `^[0-9a-fA-F]{64}$`.
- Bila valid → digunakan sebagai private key; `keyId = "prod-" + pubHex.slice(0,16)`.
- Bila kosong/tidak valid → **fallback ke kunci DEV tetap** yang tertanam di kode; `keyId = "dev-" + pubHex.slice(0,16)`, `isDev = true`.
- Kunci di-cache in-memory (cached) per instans fungsi sehingga derivasi kunci publik hanya terjadi sekali.

6.2 Dev vs Prod

Aspek	Development	Production
Sumber kunci	Konstanta <code>DEV_KEY_HEX</code> di <code>keys.ts</code> (publik)	<code>DASHAI_SIGNING_KEY</code> (env var rahasia, mis. Vercel Project Settings / <code>.env.local</code> yang tidak di-commit)
<code>keyId</code>	<code>dev-...</code>	<code>prod-...</code>
<code>isDev</code>	<code>true</code>	<code>false</code>
Status hukum	Tidak otoritatif ; ditandai pada PDF	Diperlakukan sebagai seal dashAI yang sah
Tujuan	App berjalan “out of the box” tanpa konfigurasi	Bukti yang dapat dipertanggungjawabkan

Pembangkitan kunci produksi (lihat README):

```
node -e "console.log(require('crypto').randomBytes(32).toString('hex'))"
# .env.local – JANGAN commit
DASHAI_SIGNING_KEY=<hex 64 karakter>
```

6.3 Prinsip & prosedur kunci

- **Server-only.** Private key tidak pernah diserialisasi ke respons; hanya `getPublicKeyInfo()` (kunci publik, `keyId`, algoritma, `isDev`) yang dipublikasikan via `GET /api/public-key`.
- **Distribusi kunci publik.** `/api/public-key` di-cache `max-age=3600`; verifikator memperoleh `publicKeyHex` tanpa perlu memercayai UI dashAI.
- **Rotasi.** Mengganti `DASHAI_SIGNING_KEY` menghasilkan `keyId` baru. Karena `keyId` tertanam di setiap envelope, bukti yang disegel kunci lama vs baru tetap dapat dibedakan dan diverifikasi terhadap kunci publiknya masing-masing.

- **Pemisahan dev/prod.** Awalan `keyId` dan flag `isDev` memastikan bukti dev tidak pernah tertukar sebagai produksi.
-

7 Apa yang Dibuktikan vs Tidak Dibuktikan Tanda Tangan

Keamanan bukti adalah **masalah trust**, bukan sekadar enkripsi. dashAI memilih menyatakan batas ini secara terbuka.

7.1 Yang DIBUKTIKAN tanda tangan (✓)

- **Integritas isi.** `EvidencePayload` yang ditandatangani **tidak berubah satu byte pun** sejak disegel. Mengubah pelat, kecepatan, pasal, lokasi, atau waktu → hash kanonik tidak cocok → `verifySealed` melaporkan “Hash payload tidak cocok — isi laporan telah diubah setelah disegel.”
- **Asal & waktu seal.** Envelope disegel oleh pemegang `DASHAI_SIGNING_KEY` pada `sealedAt` (waktu otoritatif server, termasuk dalam data yang ditandatangani).
- **Verifiabilitas independen.** Siapa pun dapat memverifikasi dengan kunci publik dari `/api/public-key` — tanpa memercayai UI dashAI dan tanpa lookup basis data (envelope tersemat penuh di QR/URL).
- **Komitmen terhadap media tanpa membawa media.** `mediaHashes` (SHA-256) termasuk dalam payload; mengganti citra membatalkan kecocokan hash.

7.2 Yang TIDAK dibuktikan tanda tangan (✗)

- **Provenans fisik adegan.** Tanda tangan **tidak** membuktikan kamera menyaksikan peristiwa nyata — frame berasal dari klien yang tidak tepercaya, dan orang dapat mengarahkan kamera ke layar. Karena itu dashAI bersifat **tamper-evident**, bukan **tamper-proof**.
- **Identitas subjek.** dashAI tidak mengenali wajah; tidak ada klaim “orang X”.
- **Akurasi estimasi.** Kecepatan kendaraan lain adalah **perkiraan**; sitasi pasal bersifat **indikatif**, bukan putusan hukum. Penilaian akhir tetap pada pihak berwenang.
- **Kebenaran input pihak ketiga.** `RoadContext` dari OSM adalah masukan bantu, bukan fakta yang dijamin tanda tangan.

Komitmen kejujuran (O8). dashAI tidak pernah mengklaim “tamper-proof”. Kalimat ini muncul konsisten di README, komentar `lib/crypto/sign.ts`, dan laporan PDF.

8 Peta Jalan Pengerasan (Hardening Roadmap)

Roadmap dipisahkan dengan tegas dari mitigasi yang sudah aktif. Tujuannya: **menaikkan biaya pemalsuan setinggi mungkin** sambil tetap jujur bahwa penilaian akhir berada pada pihak berwenang.

#	Item	Ancaman yang ditangani	Catatan
H1	Device attestation (Play Integrity / App Attest)	S-1 (kamera ke layar), E-1	Mengikat seal ke perangkat & aplikasi tepercaya; menyulitkan pemalsuan adegan
H2	Kontinuitas GPS	S-1, T-2	Jejak lokasi yang kontinu & konsisten mempersulit penyuntikan kejadian palsu
H3	Dashcam perangkat keras khusus (pasca-investor)	S-1, I-2/I-3	Pipeline tertutup dari kamera ke seal mengurangi permukaan manipulasi klien
H4	Backend YOLOv8/ ONNX + model helm/ pelat khusus	Cakupan deteksi	Memperluas deteksi live di luar 5 aturan saat ini
H5	Kamera kabin (driver monitoring)	Cakupan (sabuk, ponsel, kantuk)	Pasal 289 & 283 menjadi deteksi live, bukan hanya katalog
H6	Kalibrasi estimasi kecepatan kendaraan lain (error bars)	Akurasi/Repudiation	Mengubah “perkiraan” menjadi estimasi terkalibrasi dengan ketidakpastian eksplisit
H7	Rate limiting / WAF	D-2, R-3	Mengurangi abuse dan menambah jejak operasional tanpa mengganggu
H8	Integrasi platform resmi & teraudit dengan log seal & manipulasi kepolisian formal	Legitimasi, end-to-end	Prosedur verifikasi, laporan dapat diakses publik & keyId

9 Mitigasi Dipetakan ke Temuan & Perbaikan Audit

Tabel berikut menautkan temuan STRIDE ke kontrol konkret di kode, dengan sorotan pada **dua perbaikan audit** yang menjadi tulang punggung postur integritas.

9.1 Perbaikan audit 1 — Validasi input di `/api/seal`

Sebelum menyegel, server **memvalidasi dan menormalkan** payload yang masuk (`app/api/seal/route.ts`), mencegah field liar masuk ke data yang ditandatangani:

- JSON tak valid → HTTP 400 “Body JSON tidak valid.”.
- Kelengkapan wajib (`id`, `violation`, `subject`, `capturedAt`) → 400 bila kurang.
- `event.violation` in `CITATIONS` → 400 untuk jenis pelanggaran tak dikenal (juga menutup E-3).
- `subject` ∈ {`self`, `other`} → 400.
- `typeof capturedAt` === “number” → 400.
- `confidence` di-**clamp** ke `[0, 1]` (nilai non-finite → 0).

Menangani: **T-3**, **S-4**, **E-3** dan memperkuat **T-1** (mengurangi permukaan input yang ditandatangani).

9.2 Perbaikan audit 2 — Tanda tangan diverifikasi sebelum laporan dibuat (**signature-before-report**)

`/api/report` **memverifikasi envelope dulu** dan menolak membuat laporan resmi bila tidak valid (`app/api/report/route.ts`):

- `violation` in `CITATIONS` → 400 untuk jenis tak dikenal.
- `verifySealed(sealed, pubHex)`; bila `!verification.valid` → **HTTP 422** “Envelope tidak dapat diverifikasi — laporan resmi tidak dibuat.” beserta `reason`.
- Hanya envelope yang **lulus** dua pemeriksaan (`hash` + tanda tangan) yang dirender ke PDF.

Menangani: **T-1**, **R-1**, **S-2/S-3** (laporan tak pernah mengesahkan envelope rusak/palsu) dan menjaga **O1/O2/O8**.

9.3 Matriks ringkas temuan → kontrol

Temuan	Kontrol utama	Lokasi
T-1, R-1, R-2	Canonicalize + SHA-256 + Ed25519; lib/crypto/ verifySealed; sealedAt server	{canonical,sign,verify}.ts, lib/evidence/ payload.ts
T-2	sealedAt = Date.now() otoritatif	app/api/seal/ route.ts
T-3, E-3, S-4	Validasi input + guard CITATIONS + clamp confidence	app/api/seal/ route.ts
T-1 (laporan), S-2/S-3	signature-before-report (422)	app/api/report/ route.ts
I-1, E-1	server-only, kunci hanya runtime Node, hanya kunci publik diekspos	lib/crypto/ {sign,keys}.ts, app/api/public- key/route.ts
I-2, I-5	Face detection (bukan recognition) + blur default	lib/cv/face.ts
I-3	Hanya mediaHashes ke payload; media tetap lokal	lib/evidence/ payload.ts, lib/ evidence/types.ts
I-4	Pembulatan koordinat ~11 m + cache grid	lib/geo/osm.ts
D-1, D-3, D-4	Degradasi anggun (return null), try/catch render, debounce + min track age	lib/cv/pipeline.ts, lib/geo/osm.ts, app/api/report/ route.ts, lib/ violations/ engine.ts
S-2, S-3, E-4	keyId (prod-/dev-) + isDev + kunci publik terdistribusi	lib/crypto/keys.ts, app/api/{public- key,report}/ route.ts
O6 / S-4	KB hukum terverifikasi 3-voter (12/12)	lib/legal/ citations.ts, docs/ research/phase0- research.json

10 Asumsi & Keterbatasan Demo

- **Klien tidak tepercaya.** Seluruh deteksi berjalan di browser; provenans fisik adegan tidak dapat dijamin secara kriptografis pada fase ini.
- **Bukan dokumen resmi.** Laporan dashAI saat ini adalah demonstrasi; sitasi bersifat indikatif; estimasi kecepatan kendaraan lain adalah perkiraan.
- **Tanpa autentikasi pengguna & tanpa basis data** secara desain — verifiabilitas berpindah ke envelope yang ditandatangani dan dapat berdiri sendiri.
- **TLS diandalkan** untuk kerahasiaan transit; integritas end-to-end tetap dijamin tanda tangan meski TLS gagal.
- **Kunci DEV bersifat publik** dan hanya untuk pengembangan; jangan pernah memperlakukan seal dev-... sebagai otoritatif.

Pelaporan kerentanan: lihat SECURITY.md.